Cyber Intelligence GraphRAGs for Behavioral Detection

Author: Rob Heald, rheald@protonmail.com

Advisor: Fletus Poston

Accepted: *May 30th, 2026*

Abstract

Defenders increasingly face behaviorally driven adversary operations that evade indicator-based detection. Threat hunting offers a proactive alternative, but its effectiveness is bound by the quality of the initial hypothesis, which is limited by the analyst's capacity to synthesize a growing volume of *cyber threat intelligence* (CTI). This paper introduces *chatAPT*, a prototype graphRAG system that extends a hybrid dual-retrieval architecture with domain-contextualized extraction, ontologies, and entity alignment, and exposes tools that enable human analysts and AI agents to query enriched threat intelligence during hypothesis generation.

1. Introduction

The international security environment is shifting from Great Power Competition to *Great Power Confrontation*, as geopolitical tensions drive states to use cyberspace for preparatory operations (Lynch III, Mankoff, & Saunders, 2025). Network defense now extends beyond traditional foreign intelligence threats and cybercrime. As nations posture, defenders must identify and disrupt intrusions intended to pre-position access or stage effects for potential crises or conflicts.

This alarming shift in cyber-norms has drawn significant attention from threat researchers and cybersecurity-focused government organizations (Newman, 2023). In 2023, Microsoft revealed details on the intrusion set 'Volt Typhoon', highlighting two key aspects that set this campaign apart. First, Volt Typhoon targets critical infrastructure providers across sectors such as communications, manufacturing, transportation, and logistics, with a particular focus on Guam. A former NSA director described this broader targeting as a "daily contest" to deny adversary access to U.S. critical infrastructure (Haugh, 2025).

The second key differentiator in the Microsoft Volt Typhoon report is the threat actor's demonstrated proficiency in *living-off-the-land* (LotL) techniques to evade detection (Microsoft Threat Intelligence, 2023). These LotL behaviors stress modern cyber defense tools that primarily rely on static *indicators of compromise* (IOCs) as they chain commonly used binaries in a malicious combination. Determining whether a benign tool was used as part of normal network operations or with malicious intent through log analysis requires a significant understanding of a particular network's context, whereas IOCs focus on binaries previously established as malicious. As such, actors such as Volt Typhoon take advantage of opportunistic methods to gain initial access, then rely on their refined domain knowledge to guide them toward achieving their objectives.

This challenge is further amplified by advances in artificial intelligence. In November 2025, Anthropic reported that a threat actor (designated GTG-1002) leveraged one of their *large language models* (LLMs) to automate cyber intrusions against multiple targets. Within this campaign, GTG-1002 combined LLMs with AI agents to execute a variety of *tactics, techniques, and procedures* (TTPs). Many of these involved abusing

existing functionality of the target networks (Anthropic, 2025). These developments increase both the speed and scale at which adversaries can operate. This reinforces a shift toward behaviorally driven intrusion patterns that are difficult to detect using signature-based approaches alone.

Volt Typhoon and GTG-1002 highlight a broader shift that defensive systems are poorly equipped to address. IOC-driven detection constrains cyber defense to identifying known threats, while novel, adaptive threats accelerate. Although LLMs demonstrate strong reasoning and cyber operations knowledge, they lack the timely, structured, and contextual data required for threat detection. This gap separates AI's potential from its effective use in defensive cybersecurity workflows.

Closing this gap is urgent as AI-enabled intrusions may soon reduce the time defenders have to detect and respond to novel adversary behavior. While threat hunting offers a proactive counter, manual incorporation of intelligence into testable hypotheses is constrained and unlikely to keep pace with AI-augmented offensive operations. No single technical solution fully addresses this offensive advantage, but scaling proactive defense can begin by operationalizing threat intelligence—giving AI agents structured, continuously updated access to technical intelligence for hypothesis generation. This paper investigates whether a *graph-based retrieval-augmented generation* (graphRAG) system, *chatAPT*, offers a valid approach. Through controlled experiments across five organizational profiles, *chatAPT* evaluates whether tailored cyber threat intelligence (CTI) access improves the quality of LLM-generated threat-hunting hypotheses compared with general-purpose LLM reasoning alone.

2. Research Method

2.1. Current Paradigms for Cyber Threat Intelligence

For AI agents to proactively discover unknown or emerging intrusions, tailored knowledge of the nature of cyber threats is required to bolster the more general knowledge baked into LLMs during training. While LLMs know *about* cyber threats, that knowledge becomes stale as technologies evolve and new adversarial TTPs are identified.

Rob Heald, rheald@protonmail.com

CTI is shared through blog posts, formal reports, and standardized data structures such as the *Structured Threat Information Expression* (STIX). The production and aggregation of this volume of CTI impose a significant burden on an already-constrained cybersecurity workforce (ISC2, 2025), creating a pressing need for systems that operationalize threat knowledge for reasoning, not just storage.

Retrieval-Augmented Generation (RAG) addresses part of this challenge by enabling LLMs to incorporate external knowledge during inference. Documents are vectorized, and when a user submits a query, the most semantically similar content is retrieved and used as context for the LLM, allowing it to reason over domain-specific data not included in its training set (Pederson, 2025). Knowledge graphs provide a complementary approach by encoding information as entities and ontologically defined relationships, preserving the connections between adversaries, infrastructure, tools, and techniques in a structured, queryable form (Cheng, Bajaber, Tsegai, Song, & Gao, 2025). This relational structure is particularly valuable for analyzing LotL behaviors, where intelligence value emerges from sequences of benign actions and their contextual associations.

Query Type	Example Question	Why RAG Struggles	Why KGs Succeed
Multi-hop relationships	Which hosts executed processes tied to techniques used by Volt Typhoon that communicate with known malicious infrastructure?	Individual facts cannot be chained together.	Supports graph traversal techniques (host, process, technique, infrastructure – as long as ontology supports it)
Aggregation Analysis	Which techniques are most frequently associated with this intrusion set?	Creates vectors for facts within documents; not designed for counting across a corpus of data	Analysis can be performed over graph metadata (e.g. – relationships and entity counts)
Causality	What sequence of events connects this user account to a known malicious domain?	No mechanism to store ordered events	Graph algorithms support exact paths (shortest path, full lineage)
Query Type	**Example Question**	**Why RAG Succeeds**	**Why KGs Struggle**
Open-ended explanation	How does Volt Typhoon maintain persistence in critical infrastructure?	Retrieves and synthesizes detailed explanations from reports	Lacks narrative and descriptive context
Emerging Knowledge	What new AI-assisted cyberattack trends have been reported recently?	Can immediately retrieve and use new documents	Requires explicit ingestion and modeling before use
Cross-document synthesis	How have LotL techniques evolved over the past five years?	Synthesizes insights across multiple sources	No inherent summarization capability

Table 1: Comparing Capabilities of Knowledge Graphs and RAG Systems

Detecting LotL activity requires access to broad threat intelligence and the ability to reason about relationships between entities and events. Combining semantic retrieval with relationship modeling accelerates the use of threat intelligence for action.

2.2. Graph-Based RAGs for Relational Reasoning

Graph-based RAG approaches integrate these complementary strengths. Microsoft's GraphRAG introduced a foundational concept: rather than treating documents as isolated text fragments, it treats unstructured data as a network of entities and relationships, enabling retrieval guided by both semantic similarity and the underlying structure of the information (Edge, et al., 2024). This allows related entities and their interactions to be retrieved and reasoned over as a unified context, addressing the disjointed retrieval that characterizes conventional RAG systems.

However, early GraphRAG implementations introduce new tradeoffs. While they improve relational reasoning, they often depend on costly graph construction processes (in both LLM tokens and time), struggle to scale when ingesting new or updated information, and may underperform RAG on certain tasks due to incomplete/sparse graphs (Xiang et al., 2025).

LightRAG addresses these limitations by integrating semantic and graph-based retrieval within a unified framework. Rather than relying primarily on graph-derived context, LightRAG retrieves both semantically relevant unstructured data and structurally relevant graph context in parallel, preserving the breadth of the vector-based retrieval while maintaining relational reasoning capabilities. In practice, semantic retrieval surfaces relevant threat intelligence from reports while graph-based retrieval reveals how those behaviors connect to broader patterns of activity.

This dual approach is particularly important for detecting LotL activity. As LotL techniques rely on sequences of benign actions and contextual relationships rather than discrete indicators, effective detection requires both access to relevant intelligence and the ability to reason over how entities and events relate to one another. By combining semantic and relational retrieval, systems like LightRAG reduce the gaps that arise when either approach is used independently.

2.3. From Intelligence to Hypotheses

Threat hunting is the proactive, hypothesis-driven search for adversary activity that has evaded existing detection mechanisms. Unlike alert-driven triage, which responds to known signatures, hunting begins with a hypothesis. In the context of cybersecurity threat hunting, a hypothesis is a testable statement about how a specific adversary might operate within a given environment. The *Targeted Hunting integrating Threat Intelligence* (TaHiTI) framework formalizes this process as a cycle: gather intelligence, generate hypotheses, investigate against available data, and refine understanding based on findings (van Os, et al., 2018). The quality of the initial hypothesis directly constrains the effectiveness of the activity: a vague hypothesis, such as "a nation-state actor may be in our network," offers no investigative direction and lacks the direct testability required to prove or disprove it. Instead, a specific and *falsifiable* hypothesis, such as "Volt Typhoon may be using ntdsutil.exe to create Active Directory snapshots for credential harvesting on domain controllers," identifies a concrete behavior, a detection surface, and suggests a data source to examine.

Generating hypotheses of this quality is analytically demanding and requires a combination of knowledge and creativity. The analyst must understand known TTPs and their own threat model well enough to map observable TTPs within their network and assess which sensors deployed there would reveal such activity. Synthesizing hypotheses draws on the combination of knowledge discussed in Sections 2.1 and 2.2 – structured relationships between actors, techniques, and infrastructure (i.e., knowledge graphs) and narrative context about how those techniques manifest in practice (i.e., semantic retrieval). When this synthesis is performed manually, it is limited by the analyst's capacity to locate, read, and cross-reference a growing volume of CTI – a burden on the already limited cybersecurity workforce. Yet without translating this intelligence into action, organizations are poorly postured for a heightened pace and scale of adversary cyber operations.

This is the gap that *chatAPT* is designed to address. Rather than replacing the analyst's judgment, a graphRAG system can accelerate the *intelligence-to-hypothesis* pipeline by providing structured, relationship-aware access to relevant CTI at

the point of hypothesis formulation. The following sub-sections describe the system architecture, the tools it exposes to support this workflow, and the experiment designed to test whether tailored CTI via graphRAG improves the quality of threat-hunting hypotheses compared to general-purpose LLM reasoning alone.

2.4. chatAPT Design & Architecture

chatAPT is a prototype graphRAG system designed to operationalize CTI for hypothesis-driven threat hunting. The research question imposes three design requirements on any system used to test it: dual-mode retrieval that preserves both the narrative context of CTI reporting and the relationship structure linking actors, techniques, and infrastructure; CTI-native entity extraction so the resulting graph captures the entity types and relationships that underpin behavioral detection rather than generic document content; and a programmatic interface that allows an LLM agent to query the graph autonomously, isolating intelligence access as the single variable in the experiment. The remainder of this section describes how *chatAPT* satisfies each of them.

The system is deployed as four containerized services orchestrated via Docker Compose: a frontend providing a browser-based analyst interface, a FastAPI backend serving as the application layer, a Neo4j graph database storing the knowledge graph, and a Qdrant vector database storing document embeddings. The backend wraps a LightRAG implementation – the dual-retrieval framework described in Section 2.2 – which ingests information to generate the graph and vector embeddings. LLM inference and embedding generation are handled by the OpenAI API (using GPT-4o-mini and text-embedding-3-small, respectively), which is called both at ingestion time for entity extraction and at query time for response generation. Figure 1 illustrates the system architecture.

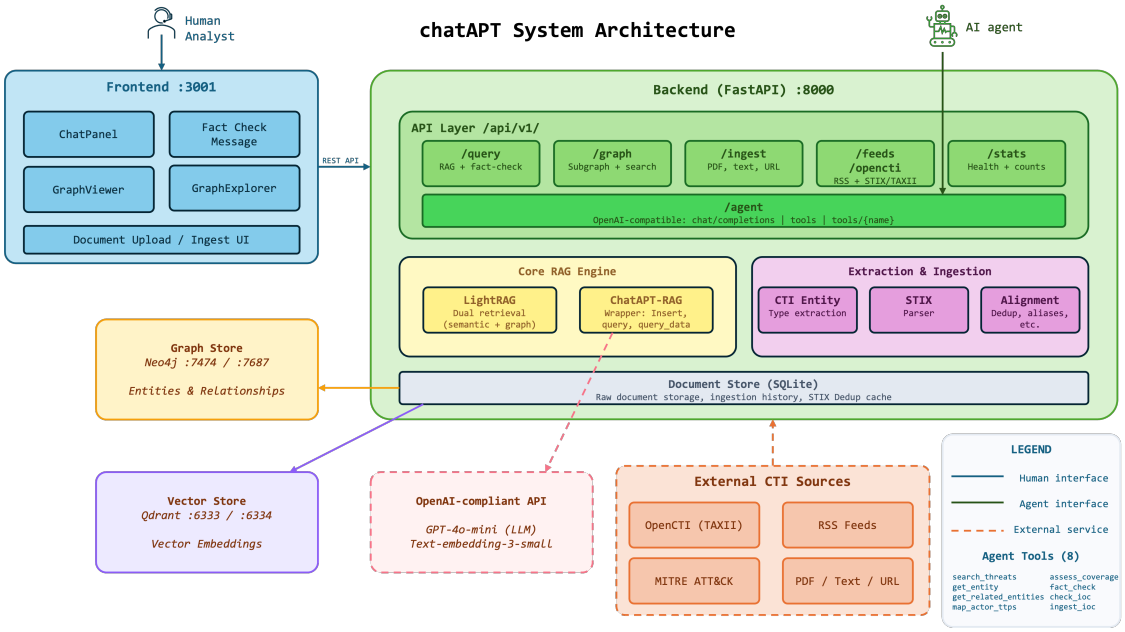


Figure 1: chatAPT System Architecture

To ensure the knowledge graph captures the entities and relationships relevant to threat hunting, *chatAPT* replaces LightRAG's default extraction prompts with CTI-specialized instructions modeled after the CTINexus approach (Cheng, Bajaber, Tsegai, Song, & Gao, 2025). These prompts direct the LLM to prioritize *MITRE ATT&CK references, indicators of compromise, CVE identifiers, threat actor aliases,* and *behavioral chains* that extract not only the key entity types but also the information required to establish relationships and the sequencing of events that underpin behavioral detection. Extracted entities are further typed using a 33-type ontology derived from MALOnt (Rastogi, Dutta, Zaki, Gittens, & Aggarwal, 2020), spanning primary types (ThreatActor, Malware, AttackPattern, Vulnerability, Campaign, Infrastructure, and others) and more specific subtypes (Ransomware, Wiper, CVE, IPAddress, etc.). This domain-specific typing enables more precise graph traversal during retrieval, allowing queries to follow typed relationships such as 'ThreatActor *uses* AttackPattern *targets* System' rather than navigating an undirected graph.

Any intelligence platform is susceptible to the 'garbage in, garbage out' problem, where derived analysis is only as useful as the information feeding the

system.

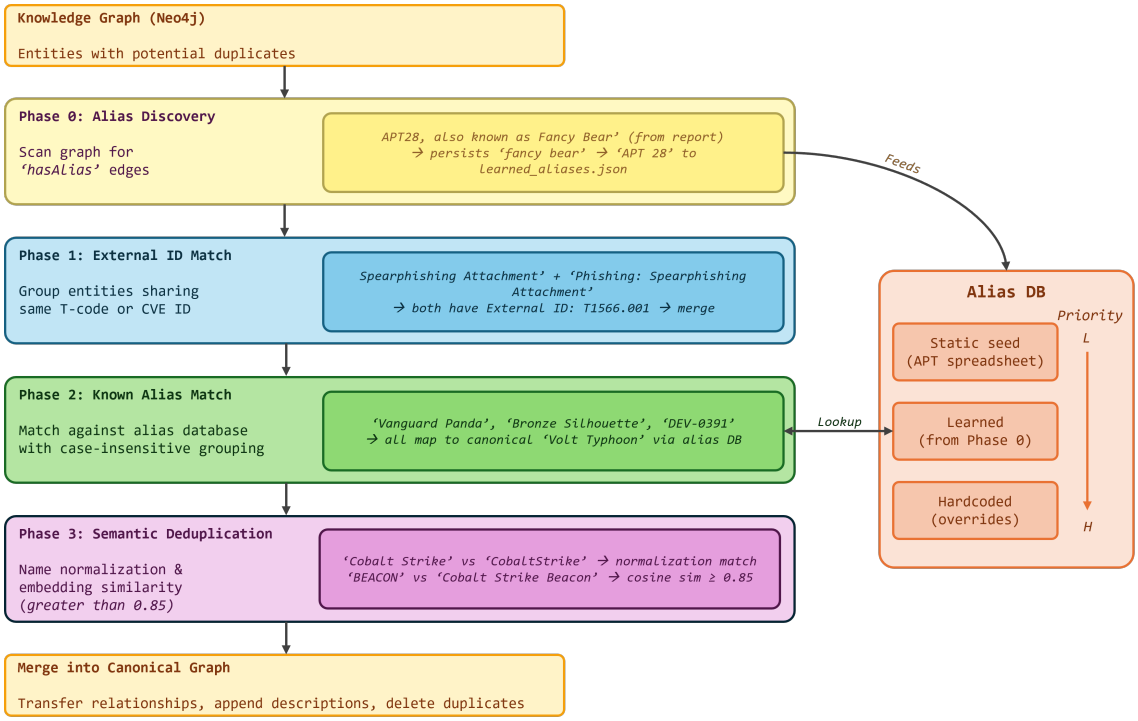


Figure 2: Entity Alignment Pipeline

chatAPT supports multiple ingestion pathways to accommodate users' preferences for various CTI formats. Unstructured sources (PDF reports, blog posts via URL, and raw text) are chunked, embedded, and processed through the entity extraction pipeline before being stored in both the vector and graph databases. Structured sources are handled through dedicated parsers. A STIX parser processes bundles from OpenCTI via its TAXII interface and converts STIX objects and relationships into graph entities, while a MITRE ATT&CK importer loads the full ATT&CK framework as a baseline reference graph. Finally, an entity alignment module (described in) runs post-ingestion for both unstructured and structured ingest paths to deduplicate entities, resolve ATT&CK T-code references to technique names, normalize CVE identifiers, and merge known threat actor aliases using resources shared by the cyber defense community (Roth, Florian, & Contributors, 2015). Without the entity alignment module, the system risks isolating key entities from each other, leading to merged accounts that reflect the isolated perspectives

of multiple intelligence providers, including private CTI vendors that use proprietary naming conventions.

To make this intelligence accessible to autonomous reasoning, *chatAPT* exposes an OpenAI-compatible API alongside a browser-based human interface. Rather than embedding autonomous reasoning within *chatAPT* itself, the system exposes eight purpose-built tools that an agent can invoke through standard function-calling conventions. As described in Table 2, these tools map directly to the phases of the TaHiTI threat-hunting workflow, spanning initial coverage assessment and broad threat search via entity traversal, TTP mapping, IOC lookup, and claim verification.

TaHiTI Phase // Activity	Agent Tool	Function
Phase I: Initiate // Trigger Hunt	assess_coverage	Evaluates knowledge base scope and identifies intelligence gaps that may warrant a hunt
	search_threats	Performs broad RAG queries to surface emerging threats relevant to the organization's profile.
Phase II: Hunt // Hypothesis Generation	map_actor_ttps	Groups an actor's techniques by ATT&CK kill chain phase to support construction of behavioral hypotheses
	get_related_entities	Traverses the graph one to three hops to identify relational chains between actors, techniques, and infrastructure
Phase II: Hunt // Hypothesis Refinement	get_entity	Retrieves a specific entity and its immediate neighborhood to add precision to a draft hypothesis
	fact_check	Validates claims against the knowledge graph, returning a verdict, confidence score, and evidence chain
Phase II: Hunt // Hunt Execution	check_ioc	Looks up specific indicators to support active hunting against known observables
Phase III: Finalize //Feedback and Enrichment	ingest_ioc	Adds newly discovered indicators back into the knowledge graph with contextual linking for future hunts

Table 2: TaHiTI/Agent Tool Mapping

This design separates the intelligence foundation from the reasoning layer: the knowledge graph sets the quality ceiling by determining what structured intelligence is available, while the agent's reasoning capability sets the floor by determining how effectively that intelligence is synthesized into actionable hypotheses. A capable reasoning model can chain multiple tool calls to perform multi-hop analysis, for example, identifying a threat actor, mapping its techniques by kill chain phase, and cross-referencing shared TTPs with other actors targeting the same sector, executing in seconds what would otherwise require an analyst to manually correlate across multiple intelligence sources.

With the architecture, ingestion pipeline, and tool interfaces in place, the system supports the evaluation of the central thesis of this paper: Does graph-based intelligence access measurably improve the quality of LLM-generated threat hunting hypotheses?

2.5. Experiment Design

2.5.1. Experiment Scenarios

Testing whether structured CTI access improves hypothesis quality requires a controlled comparison in which the intelligence system is the only variable that changes across conditions. This section describes how the experiment is constructed across the synthetic environments used to simulate realistic organizational constraints, the controlled design that isolates *chatAPT's* contribution, and the evaluation framework used to measure the quality of the resulting hypotheses.

Each experimental trial is based on a scenario representing a specific organization's security environment. Rather than testing against a single network, the experiment uses five synthetic scenarios representing distinct organizational profiles with different infrastructure, sectors, threat models, and telemetry constraints. These scenarios are encoded as DeTT&CT data-source-administration profiles. DeTT&CT (*Detect Tactics, Techniques, and Combat Threats*) is a framework for mapping an organization's detection capacity against MITRE ATT&CK TTPs by documenting which data sources are available, the platforms they cover, and a structured quality assessment across five dimensions: device completeness, data field completeness, timeliness, consistency, and retention (Bakker & Boumen, 2019). Each dimension is scored on a 0-5 scale, where 0 indicates a complete gap, and 5 indicates comprehensive, high-fidelity coverage. This structured encoding enables a systematic comparison of what an organization *can* observe with what a given threat *requires* to be detected, directly informing whether a hunting hypothesis is testable within a given environment.

The use of synthetic scenarios is deliberate for this experiment. A representative test environment implemented in a virtual environment would be limited by artificial constraints and lack the flexibility to test a wide range of hypothesis triggers. Real organizational environments introduce unknown variables that are difficult to control:

proprietary tooling configurations, inconsistent logging practices, and the ability to publish using sensitive organizational data. Synthetic profiles allow the experiment to define ground-truth gaps, ensuring each scenario has known blind spots against which hypothesis quality can be objectively assessed. For example, if a hypothesis proposes DNS-based detection in an environment where DNS logging is absent, that is a measurable failure in environment-aware reasoning. If a hypothesis explicitly accounts for that gap and proposes an alternative detection approach, it demonstrates the type of analytical reasoning this experiment seeks to measure.

The five scenarios span a range of organizational maturity, sector, and infrastructure complexity to test whether *chatAPT* provides value across realistic variation, not just in a single best-case environment. Table 3 summarizes each scenario, including the telemetry gaps intentionally built into each profile and the ATT&CK techniques most relevant to each organization's threat model.

Scenario	Threat Model	Key Assets	Telemetry Gaps	Relevant TTPs
Small business (~150 users) with hybrid SaaS and on-premises Active Directory	Ransomware deployment and business email compromise	Microsoft 365 identities, file servers, endpoints	No DNS logging, no IDS/PCAP, 14-30 day retention, sampled NetFlow	T1566, T1078, T1059, T1105, T1071
Regional hospital (~2,500 staff) with electronic health records (EHR) and segmented medical device networks	Ransomware, data theft, and disruption of clinical systems	EHR platform, identity perimeter, clinical workstations, medical device VLANs	Medical device VLAN blind spots, IDS gaps (ingress/egress only), uneven endpoint coverage	T1566, T1078, T1021, T1210, T1087, T1486
Mid-size financial firm (~3,000 users) with compliance-driven logging and network segmentation	Credential theft, fraud enablement, and persistent access to core banking systems	Core banking audit trail, identity perimeter, privileged access pathways (jump servers, remote desktop gateways, etc.)	Partial TLS inspection, short DNS retention, limited branch WAN visibility	T1566, T1078, T1098, T1556, T1059, T1046
Cloud-native Software as a Service (SaaS) provider (~800 staff) running Kubernetes and CI/CD pipelines	Supply chain compromise, cloud token theft, and data exfiltration from customer tenants	Cloud control plane, Kubernetes clusters, CI/CD runners, API gateway, object storage	Missing in-cluster DNS, partial runtime telemetry, 14-30 day retention on high-volume sources	T1078, T1552, T1195, T1621, T1087
Industrial control system operator with segmented IT/OT networks and SCADA infrastructure	Pre-positioned access and disruption of operational technology	SCADA/HMI servers, engineering workstations, ICS DMZ, OT network segments	Constrained endpoint telemetry due to vendor restrictions, partial OT sensor coverage	T0807, T0889

Table 3: Experiment Scenario Summary

Each scenario introduces specific analytical challenges that test different aspects of hypothesis generation. The Small Business scenario represents a resource-constrained organization with minimal security operations capability and significant visibility gaps, where useful hypotheses must work within narrow telemetry windows and limited data retention. The Regional Hospital scenario introduces segmented environments with

uneven coverage across medical device networks, where operational constraints and patient safety considerations limit the sensors that can be deployed. The Financial Firm offers the strongest logging posture of the five scenarios due to compliance requirements but retains specific gaps in encrypted traffic inspection and DNS retention that constrain certain detection approaches. The Cloud SaaS scenario shifts the detection surface from traditional endpoints to containers, CI/CD pipelines, and API telemetry, where aggressive retention limits on high-volume log sources force tradeoffs in what can be queried historically. Finally, the *Industrial Control System* (ICS) Operator scenario tests the boundaries of the experiment by introducing OT-specific ATT&CK techniques and an environment in which vendor support agreements and operational risk directly constrain permissible monitoring on critical systems.

Variation in scenarios is an important characteristic, as a system that improves hypothesis quality only in well-instrumented environments would have limited practical value. Organizations most in need of AI-augmented threat hunting often overlap with those with the most constrained detection capabilities. By including scenarios ranging from a small business with no dedicated SOC to a compliance-driven financial firm with mature logging, the experiment tests whether access to structured CTI via *chatAPT* delivers consistent value across a spectrum of representative environments.

2.5.2. Experimental Conditions

The experiment isolates a single variable: whether the LLM agent has access to *chatAPT's* structured knowledge graph tools during hypothesis generation. All other variables are held constant across the experiment.

In the *control* group, a threat-hunter agent receives the DeTT&CT environment profile for the scenario and a hunt prompt that describes the tasking. It has access to a single tool, `read_environment_profile`, which returns the full telemetry profile, including data source names, quality scores, and gap annotations. The agent generates its hypotheses using only the LLM's training knowledge of cyber threats. It has no access to *chatAPT* or any external threat intelligence.

In the *experimental* group, the agent receives the same environment profile, the same hunt prompt, and the same `read_environment_profile` tool. In addition, it has

access to *chatAPT's* eight agent tools described in Table 2. This gives it the ability to search the knowledge graph for relevant threats, traverse relationships between actors and techniques, map an actor's TTPs by kill-chain phase, look up specific indicators, and verify claims against the intelligence base. The agent decides which tools to call, in what order, and how to incorporate the results into hypothesis generation. The only difference between groups is access to these tools.

Both groups use the same LLM (GPT-4o-mini), the same LLM temperature (0.7), the same maximum number of tool-calling turns (15), and the same system prompt instructing the agent to generate structured, falsifiable hunting hypotheses. This design ensures that any observed difference in hypothesis quality can be attributed to the availability of structured CTI access rather than differences in model capability, prompt engineering, or environmental context.

The knowledge graph available to the experimental condition was populated from 980 sources prior to the experiment, producing a graph of (at the time of the experiment) 102K entities and 459K relationships. These sources span four categories: government advisories, published threat intelligence reports, security research blogs, and structured STIX intelligence bundles ingested from an OpenCTI instance via its TAXII interface, providing curated threat actor profiles, malware definitions, vulnerability records, indicators of compromise, and their associated relationships in STIX 2.1 format.

In addition to manually ingested reports and the full MITRE ATT&CK Enterprise framework, *chatAPT* continuously ingests new intelligence through subscribed RSS feeds that are polled for updates. All ingested content is processed through the CTINexus-style extraction prompts and entity alignment described in Section 2.4, and a content quality filter removes material scored as commentary, marketing, or otherwise low in actionable intelligence value. A curated alias database of over 300 threat actor name mappings compiled from public threat group tracking spreadsheets (Roth, Florian, & Contributors, 2015) further supports entity deduplication across vendor naming conventions. This corpus defines the experimental group's ceiling: if a relevant threat, technique, or relationship is not represented in the knowledge graph, the experimental group cannot surface it, regardless of the agent's reasoning capability. There are many valuable paid

providers of high-quality CTI that would likely enhance results considerably; however, for this experiment, *chatAPT* was not given access to such providers.

3. Research Findings & Discussion

3.1. Experiment Run Structure

Each scenario is tested with three hunt prompts, each targeting a different analytical challenge. The first prompt in each scenario focuses on LotL detection, asking the agent to generate hypotheses about specific adversary techniques relevant to the organization's threat model and available telemetry. The second targets compensating-control reasoning, asking the agent to work around known gaps in the environment's telemetry to propose alternative detection approaches. The third focuses on data-gap identification, asking the agent to assess which missing telemetry sources would provide the greatest improvement in detection capability if addressed.

Each prompt is run under both conditions, producing 6 trials per scenario and 30 trials across the full experiment. The two-agent pipeline processes each trial in sequence. First, the Threat Hunter agent generates hypotheses based on the environment profile, the hunt prompt, and (in the experimental group) any intelligence retrieved from *chatAPT*. The Threat Hunter outputs structured JSON containing 3 to 5 hunting hypotheses, each specifying the targeted actor or threat, referenced ATT&CK techniques, a step-by-step behavior chain, required data sources, a feasibility assessment against the environment's telemetry, expected observables, false-positive considerations, and explicit proof and disproof criteria. The output also includes 1 to 3 data-gap hypotheses identifying missing telemetry, the threats that cannot be detected as a result, and a prioritized remediation recommendation.

Second, a *security operations center* (SOC) analyst agent receives the Threat Hunter's hypotheses and translates them into executable hunt plans. For each hypothesis, the SOC Analyst checks data feasibility against the DeTT&CT profile, generates Sigma detection rules in vendor-agnostic YAML format, and produces a step-by-step query and validation plan that an analyst could execute. Hypotheses that the SOC analyst

determines are infeasible given the environment's telemetry are flagged with an explanation of what data sources are missing and a suggested alternative approach. The SOC Analyst stage serves as a ground-truth feasibility check, but the primary evaluated output of the experiment is the Threat Hunter's hypotheses. Section 3.2 describes the rubric used to score them.

3.2. Evaluation Framework

Measuring the quality of threat-hunting hypotheses requires a rubric that assesses whether a hypothesis is operationally useful, not just whether it sounds reasonable. A well-written hypothesis that references a plausible threat but ignores the environment's telemetry constraints is no more actionable than a vague one. The evaluation framework used in this experiment combines a structured scoring rubric with blinded expert review to assess hypothesis quality across the dimensions that matter most to the analysts who would act on them.

The *Hypothesis Utility Score* (HUS) is a seven-dimensional rubric for evaluating the operational quality of a threat-hunting hypothesis. Each dimension is scored on a 1 to 5 scale, producing a total score ranging from 7 (low quality across all dimensions) to 35 (high quality across all dimensions). The seven dimensions are summarized in Table 4.

Dimension	Definition	1 (Low)	3 (Moderate)	5 (High)
Clarity and Specificity	Does the hypothesis identify a specific actor or threat, name concrete techniques, and scope the targeted systems?	Vague reference to generic threats with no named techniques or systems	Names a threat category and some techniques but lacks precision on scope or target systems	Names a specific actor or threat, references exact ATT&CK techniques, and bounds the hypothesis to specific systems or segments.
Falsifiability	Can the hypothesis be definitely proven or disproven using defined criteria?	No criteria for validation; the hypothesis cannot be tested in a meaningful way	Partial criteria exist but the outcome could be ambiguous	Explicit proof and disproof criteria are defined, leading to a clear validation outcome
Data feasibility	Is the hypothesis testable with the telemetry actually available in this environment?	Depends on data sources that are absent or have quality gaps	Some required data sources are available but coverage or retention constraints limit confidence	All required data sources are present with sufficient quality and retention to support the hypothesis
Explainability	Does the hypothesis present a clear causal narrative that an analyst can follow and trust?	No reasoning provided; the hypothesis reads as an unsupported assertion	Some reasoning is present but gaps in the causal chain require the analyst to fill in assumptions	A complete causal narrative explains why this behavior would occur, what it would look like, and how benign explanations are ruled out.
Actionability	If the hypothesis is validated, does it directly trigger a specific response such as incident response, detection engineering, or control improvement?	No clear action follows from validation	A general response direction is implied but not defined	Explicit decision rules specify what action to take based on specific evidence thresholds

Novelty and Gap Value	Does the hypothesis surface non-obvious threats or identify meaningful blind spots that the organization would not have considered otherwise?	Restates well-known threats without adding environmental or relational context	Applies known threats to the specific environment but does not reveal new relationships or gaps	Surfaces non-obvious connections between actors, techniques, or infrastructure, or identified high-impact telemetry gaps tied to specific adversary behavior
Signal-to-Noise	Does the hypothesis anticipate false positives and include strategies for disambiguation	No consideration of false positive drivers	Acknowledges that false positives may occur but offers no mitigation approach.	Identifies the primary false positive drivers for each detection and includes specific disambiguation steps or planned pivots

Table 4: Hypothesis Utility Score (HUS) Rubric

These dimensions map directly to the qualities that determine whether a hypothesis drives a productive hunt cycle or wastes analyst time. A hypothesis that scores well on clarity and specificity but fails on data feasibility cannot be executed. A hypothesis that scores well on data feasibility but fails on actionability produces findings that lead nowhere. The HUS rubric is designed to account for hypotheses that are strong in one area but are hindered in another, enabling a holistic assessment of the overall hypothesis.

The HUS rubric was used by a panel of 10 cybersecurity subject matter experts with experience across forensic analysis, threat hunting, incident response, penetration testing, and other practical applications within the domain. Each review receives a set of hypothesis pairs, consisting of one hypothesis generated under the control group and one under the experimental group for the same scenario and hunt prompt. Reviewers did not know which hypothesis came from which group, ensuring that scores reflect the perceived quality of each hypothesis rather than expectations about its source.

3.3. Experiment Results

Section 2.5.2 described a 30-trial experiment run comparing two conditions: a control agent with no knowledge graph access, and an experimental agent equipped with chatAPT's threat intelligence tools. Both conditions operated on identical scenarios, environments, and hunt prompts – the only variable was whether the agent could query the knowledge graph before generating hypotheses. All 30 trials were completed successfully, producing at least 90 hunting hypotheses across five scenarios.

This section presents findings from that run. Section 3.3.1 introduces a representative hypothesis pair and demonstrates how the HUS rubric applies to it, setting an example of how the analysis was performed for the experiment as a whole. Section 3.3.2 analyzes qualitative differences in hypotheses across groups, and Section 3.3.3 presents findings from *subject-matter expert* (SME) evaluations.

3.3.1. Exemplar Hypothesis and Scoring

A scenario based on a financial firm produced the clearest qualitative contrast between conditions and serves as an illustrative example. The scenario involves a mid-sized company (~3,000 users) with strong compliance-oriented logging, Azure *Active Directory* (AD) and *AD Federation Service* (AD FS) infrastructure, and short DNS log retention. The hunt prompt asked for identity-first hypotheses for stealthy persistence and privilege escalation, specifying which correlated audit and authentication log artifacts would confirm or deny each.

Control Group Example: A threat actor is using Azure AD OAuth tokens to maintain persistence and escalate privileges within the environment.

The control agent attributed this hypothesis to “Cozy Bear (APT29)” in the actor field but opened the hypothesis statement itself with the generic phrase “a threat actor.” It applied ATT&CK techniques T1135, T1078.001, and T1203 and described a behavior chain based on malicious OAuth application registration. Proof criteria specified “at least two instances of abnormal OAuth token requests within a 30-day period” without defining what an abnormal request looks like. False-positive guidance directed the analyst to “cross-reference with user behavior and account activity patterns,” without specifying which patterns or thresholds to use.

Experimental Group Example: APT29 is modifying the Microsoft.IdentityServer.Servicehost.exe.config file to inject a malicious DLL for persistent access.

The experimental agent queried the knowledge graph for threats targeting federated identity infrastructure, retrieved APT29's documented behavioral chain for this environment type, and built the hypothesis around a specific persistence mechanism: modifying the AD FS host configuration file to load a malicious DLL into the identity server process. ATT&CK techniques were T1574 (Hijack Execution Flow) and T1055 (Process Injection). Proof criteria required at least two unauthorized modifications to the named configuration file within 30 days, corroborated by additional process creation events for unexpected DLLs. Notably, when evaluating the hypothesis for potential data gaps based on the DeTT&CT profile, the agent concluded that "*None identified; all necessary logs are available for this hypothesis*."

When applying the HUS rubric to each hypothesis, four dimensions produced notably different results, while three dimensions (actionability, signal-to-noise, and data feasibility) provided consistent responses and were omitted for brevity. These are described in Table 5.

Dimension	Control Hypothesis	Experimental Hypothesis
Clarity & Specificity	Names APT29 in the actor field but the hypothesis statement itself uses a "threat actor"; target is described as "the environment" rather than a specific system or service. *Score: 3*	Names APT29 explicitly; specifies the exact configuration file, the target process (AD FS), and the injection mechanism. *Who*, *what*, and *where* questions were all answered. *Score: 5*
Falsifiability	Proof threshold defined (2 instances) but the key term "abnormal" is left undefined; an analyst cannot determine in advance what would constitute a disconfirming result. *Score*: *3*	Proof requires documented modifications to the named file, corroborated by DLL process creation logs as separate artifacts with explicit thresholds. Disproof criteria are equally specific. *Score: 5*
Explainability	Behavior chain describes OAuth token acquisition generically; does not connect the named actor's known tradecraft to the specific Azure AD configuration in this environment. *Score: 3*	Behavior chain traces APT29's documented method (configuration file modification *to* DLL load *to* persistent AD FS access) and connects it directly to the environment's identity infrastructure. An analyst unfamiliar with the specific actor can follow the reasoning. *Score: 5*
Novelty & Gap Value	OAuth token abuse is a well-documented identity TTP and the hypothesis does not reveal anything a generic identity-focused hunt would miss. Techniques are not tailored to the AD footprint of the environment. *Score: 2*	AD FS configuration modification for DLL injections is a documented but non-obvious APT29 persistence mechanism; without the knowledge graph surfacing this behavior, a generic hunt would be unlikely to prioritize it. *Score: 5*

Table 5: Hypothesis Rubric Evaluation

The pattern across these dimensions illustrates the structural difference between the two groups. The control hypothesis is coherent and draws on legitimate threat knowledge, but its specificity is bounded by what a skilled analyst could recall without additional intelligence. The experimental hypothesis is constructed around a specific behavioral observation retrieved from the knowledge graph. The HUS rubric captures this

distinction across multiple independently scored dimensions, providing a basis for the comparative evaluation described in Sections 3.3.2 and 3.3.3.

3.3.2. Analysis of Hypothesis Content

Three patterns distinguish the experimental group's output from the control group across the five scenarios.

The control group references 30 distinct threat actor names across 15 trials, while the experimental group references 17. The lower count reflects a combination of factors: greater selectivity based on the scenario, and a limitation of the data set ingested into *chatAPT* at the time of analysis. For selectivity, the experimental agent queried the knowledge graph for actors with documented relevance to each scenario's threat model. This selectivity also led to more accurate attributions, according to the author's assessment. Several control hypotheses named penetration testing tools as threat actors themselves, with "Cobalt Strike" and "Mimikatz" appearing as actors across multiple trials, while others used generic placeholders or approximate attributions ("Russian Cyber Espionage Group (e.g., APT28)"). In the small business scenario, the control group attributed its three hypotheses to "Cobalt Strike," "Generic Web Application Exploiter", and "Insider Threat," while the experimental agent queried for threats relevant to hybrid-office environments, retrieved Mustang Panda's documented PlugX deployment campaigns, and anchored all three hypotheses around that actor's known behavioral chain.

Beyond actor names, experimental hypotheses referenced specific intelligence artifacts such as named malware families, specific CVEs retrieved from the knowledge graph and documented behavioral chains connecting actors to techniques through prior operational context. The AD FS configuration injection hypothesis in Section 3.3.1 illustrates the value of the combination with a testable, specific claim constructed from retrieved intelligence rather than generated from the LLM's training set. Ultimately, control hypotheses tended to name a technique and an actor without establishing a documented behavioral link between them and the specific environment, whereas the best results from the experimental group demonstrated specificity as driven by the available intelligence.

The gap was perhaps most pronounced in the ICS Operator scenario, which requires familiarity with operational technology environments and contextualized techniques as described in ICS-specific ATT&CK. The control group applied Enterprise ATT&CK technique identifiers to an operational technology (OT) environment writ large, including one instance in which T1553.003 (SIP and Trust Provider Hijacking) was misidentified in the hypothesis text as "External Remote Services" (likely an LLM hallucination). All three control hypotheses used standard Enterprise TTPs, and the attributed actors (APT10, APT28, and a generic "Chinese APT") were drawn from enterprise threat categories that do not appear to be linked to ICS infrastructure. The experimental agent's ICS hypotheses attributed all three to Iranian-affiliated cyber actors with documented *supervisory control and data acquisition* (SCADA) targeting, cited exploitation of the CODESYS vulnerability, and used ICS ATT&CK identifiers alongside Enterprise techniques. This domain specificity was a direct result of the knowledge graph surfacing OT-relevant threat intelligence that the base model did not prioritize when generating hypotheses without access to tools. That significance is reinforced by Iranian cyber operations against critical infrastructure that have escalated amid active geopolitical conflict, demonstrating why a continuously updated knowledge graph matters: emerging actor activity surfaces in near-real time rather than waiting for a model's next training cycle.

3.3.3. Subject Matter Expert Review

Ten subject matter experts completed blinded evaluations of hypothesis pairs across all five scenarios. Experimental group hypotheses were preferred 56% to control hypotheses (32%), with the remainder tied (12%). Given the SME panel size, these results should be read as indicative rather than conclusive, with the per-scenario breakdown providing deeper analysis.

Scenario	CON Preferred	EXP Preferred	Tie	CON AVG	EXP AVG	Delta
Small Business	1	9	0	18.8	25.1	+6.3
Regional Hospital	5	3	2	22.2	21.7	-0.5
Financial Firm	0	9	1	21.7	28.9	+7.2
Cloud SaaS	7	1	2	22.2	21.1	-1.1
ICS Operator	3	6	1	22.5	23.8	+1.3

Rob Heald, rheald@protonmail.com

Overall	16	28	6	22.1	24.3	+2.2

Table 6: Review Scoring

The Financial Firm and Small Business scenarios represent the strongest case for structured CTI access, with experimental hypotheses preferred in 9 of 10 evaluations apiece and score deltas of +7.2 and +6.3, respectively. Both scenarios were supported by documented, technique-level behavioral chains in the graph. Finance surfaced APT29 modifying Microsoft.IdentityServer.Servicehost.exe.config to inject a DLL in AD FS. Small Business surfaced Mustang Panda's documented PlugX deployment. The control agent named APT29 in Finance as well, but without graph retrieval, it produced a generic OAuth persistence chain of the kind base models generate from their training data. The experimental hypothesis focused on a specific file that a SOC could immediately investigate. Evaluator responses on both scenarios cited the specificity of proof criteria and the traceability of the behavioral reasoning as the basis for the preference.

The Regional Hospital and Cloud SaaS scenarios provided instructive feedback, highlighting gaps in existing *chatAPT* knowledge/capability. In both cases, the experimental agent retrieved a correctly scoped actor (APT29 for Hospital, Slow Pisces for Cloud), but the graph lacked documentation of how those actors operated within target environments similar to the presented scenarios. Anchored to the profile it could retrieve, the experimental agent produced a generic behavioral chain that *could* apply to the target sector, but lacked the specificity of Finance and Small Business. The control agent, operating without that anchor, drew on the base LLM's training knowledge and produced hypotheses more operationally aligned to the scenario. In the hospital, control specified RDP (T1021.002) as the lateral movement mechanism, which an evaluator flagged as a testable anomaly in a clinical environment where clinicians typically access electronic health records via local workstations. The experimental hypothesis used a generic lateral movement reference without naming a mechanism. In Cloud, control constructed a more complete CI/CD kill chain, whereas the experimental hypothesis left the initial access step at the level of the actor's phishing credentials, then escalated privileges. Cloud SaaS produced the experiment's most decisive preference, as seven evaluators favored the control hypothesis against one for the experimental group.

Given the small sample size of the review, this may indicate that the threat narrative does not necessarily improve when retrieval surfaces an actor without detailed, technique-level context to explain how that actor operates specifically within the target environment. For specialized domains such as healthcare, operational technology, and the defense sector, hypothesis quality depends on intelligence that documents adversary behavior inside those environments rather than inferring exclusively from enterprise IT.

The ICS scenario was split 6 EXP/3 CON/1 tie, falling in between the strongest and weakest cases. Qualitatively, the experimental agent attributed its hypotheses to Iranian-affiliated actors with documented SCADA targeting and referenced CODESYS vulnerability exploits, framing that reflects active geopolitical conflict at the time of writing and would be difficult to produce solely from model training. This is a useful demonstration of what continuous ingestion into a graphRAG enables: the actor attribution surfaced timely, technically specific intelligence that the base model could not produce, and was sufficient for evaluators to prefer the experimental hypothesis on a majority of trials.

Taken together, these results support a qualified affirmative answer to the research question: graphRAG-augmented hypothesis generation produced measurably better hypotheses when the knowledge graph carried specific, technique-level intelligence aligned with an organization's threat surface, and produced weaker hypotheses when it did not. This pattern underscores the importance of identifying sufficiently technical, relevant intelligence to feed the system and would drive the greatest initial improvement in this experiment.

4. Recommendations & Implications

The experimental results in Section 3.3 support two findings worth highlighting. First, the architectural approach is operationally viable. In the strongest scenarios, the experimental group generates hypotheses anchored to specific artifacts retrieved from the graph, to include named configuration files, documented behavioral chains, and actor-technique mappings that a base model could not extract from its training set alone. That this occurred with an eighteen-month-old model (GPT-4o-mini), a 33-type ontology, and a minimally modified LightRAG retrieval setup suggests the architectural approach is

operationally viable on its own merits. Further investment in the ontology, graph traversal heuristics, and the tool interfaces/prompts is likely to substantially extend these gains.

Second, coverage depth in the graph governs where such gains are realized. Two scenarios produced strong results because the graph surfaced specific artifacts that the control group had no retrieval path to. The other scenarios showed the opposite – where the experimental group named the correct actor but lacked the operationally-specific techniques to generate as strong hypotheses. Sustained ingestion of targeted threat-intelligence feeds and domain-specific sources of expertise is likely to shift these scenario-level outcomes more than any single architectural change. Thus, identifying and mapping data feeds to a prioritized threat model should be an important consideration for any operational deployment of *chatAPT*.

An additional research pathway worth pursuing is varying the underlying embedding and language model. The experiment used GPT-4o-mini to hold capability constant across test runs, isolating the effect of retrieval but leaving open how *chatAPT's* improvements scale with model performance. A smaller open-weights model quantized for air-gapped or mobile hunt-kit deployments represents one operationally-relevant possibility, whereas a frontier model with richer tool-use reasoning represents the opposite. Characterizing the architectural impact on the base model capability would directly inform deployment decisions for organizations whose constraints fall at either extreme.

The scenarios where *chatAPT* did not measurably improve hypotheses raise an additional deployment consideration: like many LLM-enabled applications, the capability produced authoritative-sounding hypotheses in domains where its underlying coverage was thin, risking a trust problem for analysts who treat 'specificity' as a proxy for 'evidence'. Exposing graph density metrics and other functionality (e.g., node counts, ingestion recency, fact-checks) would provide analysts with tools to calibrate their skepticism accordingly.

Taken together, these implications point toward a deployment posture where *chatAPT* could accelerate the analyst's throughput rather than replace their judgment altogether. The workforce and speed pressures that motivated this work in

Section 1 remain: defenders cannot scale human analysts at the pace adversaries are scaling automated operations, and a graphRAG system that narrows the time between intelligence publication and testable hypothesis directly addresses that asymmetry where coverage permits.

5. Conclusion

This paper asked whether structured, relationship-aware access to CTI via a *chatAPT*-style graphRAG system could measurably improve the quality of LLM-generated threat-hunting hypotheses. When the knowledge graph contains dense, technical-level documentation of adversary behavior, the system produces hypotheses that analysts can act on immediately. However, gaps in the knowledge graph regarding threat actors or technical domains stand out and underscore the critical takeaway for those seeking to test in more operational environments.

For defenders, the practical takeaway is that operational value depends on whether the corpus carries intelligence aligned to the threat model the organization actually faces. Curating that corpus is just as important as the graphRAG solution itself. A deployment paired with thin data will produce a system that generates authoritative output without being much more useful than what a capable analyst could derive from accessing an LLM directly. A deployment paired with rich intelligence that is aligned to an organization's threat model will produce output that can accelerate proactive defensive measures.

The underlying problem is one of scale. Adversaries like Volt Typhoon and GTG-1002 are pressuring defenders to reason about behavior rather than indicators at a tempo no amount of hiring is likely to match. A graphRAG system narrows the gap between intelligence publication and testable hypothesis, and its ceiling rises with the quality of intelligence feeding it and the ontology that organizes it. The asymmetry these threat actors represent will not be mitigated by any single tool, but operationalizing CTI for proactive defense is a valuable step in the right direction.

References

Anthropic. (2025, November 17). *Disrupting the First Reported AI-orchestrated cyber espionage campaign.* Retrieved from Anthropic: https://assets.anthropic.com/m/ec212e6566a0d47/original/Disrupting-the-first-reported-AI-orchestrated-cyber-espionage-campaign.pdf

Bakker, M., & Boumen, R. (2019, May 8). *DeTT&CT: Mapping your Blue Team to MITRE ATT&CK.* Retrieved from MB Secure: https://www.mbsecure.nl/blog/2019/5/dettact-mapping-your-blue-team-to-mitre-attack

Cheng, Y., Bajaber, O., Tsegai, S., Song, D., & Gao, P. (2025, September 28). *CTINexus: Automatic Cyber Threat Intelligence Knowledge Graph Construction Using Large Language Models.* Retrieved from arXiv: https://arxiv.org/pdf/2410.21060

Edge, D., Trinh, H., Cheng, N., Bradley, J., Chao, A., Mody, A., . . . Larson, J. (2024, April 24). *From Local to Global: A GraphRAG Approach to Query-Focused Summarization.* Retrieved from Arxiv: https://arxiv.org/pdf/2404.16130

Haugh, G. T. (2025, October 12). China Hacking U.S. Critical Infrastructure. (S. Pelley, Interviewer)

ISC2. (2025, December). *Cybersecurity Professionals Navigate Evolving Workplaces While Seizing New Opportunities.* Retrieved from ISC2: https://edge.sitecorecloud.io/internationf173-xmc4e73-prodbc0f-9660/media/Project/ISC2/Main/Media/insights/Features/2025/12/COMMS_2025_Cybersecurity_WFS_Report_Whitepaper.pdf

Lynch III, T. F., Mankoff, J., & Saunders, P. C. (2025, February 24). *Mid-Decade Great Power Geostrategic Dynamics.* Retrieved from National Defense University Press: https://ndupress.ndu.edu/Portals/68/Documents/Books/SA2025/Chap3a_Strategic_Assessment_2025.pdf

Microsoft Threat Intelligence. (2023, May 24). *Volt Typhoon targets US critical infrastructure with living-off-the-land techniques*. Retrieved from Microsoft.com:

https://www.microsoft.com/en-us/security/blog/2023/05/24/volt-typhoon-targets-us-critical-infrastructure-with-living-off-the-land-techniques/

Newman, L. H. (2023, November 10). *The NSA Seems Pretty Stressed About the Threat of Chinese Hackers in US Critical Infrastructure*. Retrieved from wired.com: https://www.wired.com/story/nsa-china-hacking-criticial-us-infrastructure/

Pederson, J. (2025, June 12). *Retrieval-Augmented Generation (RAG).* Retrieved from Pinecone.io: https://www.pinecone.io/learn/retrieval-augmented-generation/

Rastogi, N., Dutta, S., Zaki, M. J., Gittens, A., & Aggarwal, C. (2020, June 20). *MALOnt: An Ontology for Malware Threat Intelligence.* Retrieved from Arxiv.org: https://arxiv.org/abs/2006.11446

Roth, Florian & Community Contributors. (2015, December 26). *APT Groups and Operations.* Retrieved from APT Threat Tracking: https://apt.threattracking.com

van Os, R., Bakker, M., Bouman, R., van Leeuwen, M. D., van der Kraan, M., Mentges, W., & Piers, A. (2018, December 17). *TaHiTI Threat Hunting Methodology.* Retrieved from Nederlandse Vereniging van Banken: https://www.nvb.nl/media/rygbrwew/def-tahiti-threat-hunting-methodology.pdf

Xiang, Z., Wu, C., Zhang, Q., Chen, S., Hong, Z., Huang, X., & Su, J. (2025, June). *When to use Graphs in RAG: A Comprehensive Analysis for Graph Retrieval-Augmented Generation.* Retrieved from ResearchGate: http://researchgate.net/publication/392514752_When_to_use_Graphs_in_RAG_A_Comprehensive_Analysis_for_Graph_Retrieval-Augmented_Generation